

WebVulnPro Security Assessment Report

Generated: 2026-07-17 21:00:25

Executive Summary

Targets Scanned	1
Total Vulnerabilities	22
Critical	1
High	4
Medium	8
Low	5
Informational	4
Overall Risk Score	100/100

Technologies Detected

■ CMS

Technology	Version	Confidence
WordPress	-	80%

■■ Framework

Technology	Version	Confidence
ASP.NET	2.0.50727	89%

■■ Web Server

Technology	Version	Confidence
IIS	8.5	35%

■ Operating System

Technology	Version	Confidence
Windows Server	-	35%

Target: <http://testaspnet.vulnweb.com/login.aspx>

Severity	Title	CVSS	Category
CRITICAL	WordPress Config Backup Exposed	9.8	CMS Security
HIGH	Missing Content Security Policy (CSP)	7.1	HTTP Headers
HIGH	Git Repository Exposed	7.5	CMS Security
HIGH	WordPress Debug Log Exposed	7.5	CMS Security
HIGH	Backup/Sensitive Files Exposed (26 found)	7.5	Information Disclosure
MEDIUM	Missing X-Frame-Options Header	5.4	HTTP Headers
MEDIUM	Missing X-Content-Type-Options Header	5.3	HTTP Headers
MEDIUM	Missing Referrer-Policy Header	4.3	HTTP Headers
MEDIUM	Missing Permissions-Policy Header	4.3	HTTP Headers
MEDIUM	Forms Missing CSRF Protection	5.3	CSRF
MEDIUM	Potential HTTP Request Smuggling Vector	5.3	HTTP Protocol
MEDIUM	WordPress User Enumeration via REST API	5.3	CMS Security
MEDIUM	WordPress Uploads Directory Listing	5.3	CMS Security
LOW	Server Version Disclosure	2.6	Information Disclosure
LOW	ASP.NET Version Disclosure	2.6	Information Disclosure
LOW	WordPress XML-RPC Enabled	3.7	CMS Security
LOW	WordPress Version Exposed	2.0	CMS Security
LOW	WordPress Includes Directory Accessible	2.0	CMS Security
INFO	Robots.txt Found	0.0	Sensitive Path Exposure
INFO	API Endpoints Discovered (38 found)	0.0	Information
INFO	Hidden Parameters Discovered (98 found)	0.0	Information
INFO	WordPress REST API Accessible	0.0	CMS Security

Detailed Findings

[CRITICAL] WordPress Config Backup Exposed

CVSS Score: 9.8 | **Category:** CMS Security | **CWE:** CWE-200

Description: A backup of wp-config.php containing database credentials may be accessible.

Remediation: Remove backup files from the web root.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/wp-config.php.bak> Status: 200

[HIGH] Missing Content Security Policy (CSP)

CVSS Score: 7.1 | **Category:** HTTP Headers | **CWE:** CWE-1021

Description: No Content-Security-Policy header found. This makes the application vulnerable to XSS and data injection attacks.

Remediation: Implement a strict CSP. Start with: Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none'

Evidence: Header 'content-security-policy' not found in response

[HIGH] Git Repository Exposed

CVSS Score: 7.5 | **Category:** CMS Security | **CWE:** CWE-200

Description: Git repository configuration is exposed.

Remediation: Remove .git directory or block access via web server configuration.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/.git/config> Status: 200

[HIGH] WordPress Debug Log Exposed

CVSS Score: 7.5 | **Category:** CMS Security | **CWE:** CWE-200

Description: WordPress debug log may contain sensitive information.

Remediation: Disable WP_DEBUG_LOG in production or move logs outside web root.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/wp-content/debug.log> Status: 200

[HIGH] Backup/Sensitive Files Exposed (26 found)

CVSS Score: 7.5 | **Category:** Information Disclosure | **CWE:** CWE-200

Description: Backup or sensitive configuration files are publicly accessible.

Remediation: Remove backup files from web root or restrict access.

Evidence: Files found: web.config, web.config.bak, web.config.old, .htaccess, .htaccess.bak, .htpasswd, config.php, config.php.bak, config.inc.php, database.yml

[MEDIUM] Missing X-Frame-Options Header

CVSS Score: 5.4 | **Category:** HTTP Headers | **CWE:** CWE-1021

Description: X-Frame-Options header is missing. The site may be vulnerable to clickjacking attacks.

Remediation: Add 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' header.

Evidence: Header 'x-frame-options' not found in response

[MEDIUM] Missing X-Content-Type-Options Header

CVSS Score: 5.3 | **Category:** HTTP Headers | **CWE:** CWE-693

Description: X-Content-Type-Options header is missing. Browsers may MIME-sniff responses, potentially executing malicious content.

Remediation: Add 'X-Content-Type-Options: nosniff' header.

Evidence: Header 'x-content-type-options' not found in response

[MEDIUM] Missing Referrer-Policy Header

CVSS Score: 4.3 | **Category:** HTTP Headers | **CWE:** CWE-200

Description: Referrer-Policy header is missing. Sensitive information may leak via the Referer header.

Remediation: Add 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer' header.

Evidence: Header 'referrer-policy' not found in response

[MEDIUM] Missing Permissions-Policy Header

CVSS Score: 4.3 | **Category:** HTTP Headers | **CWE:** CWE-16

Description: Permissions-Policy (formerly Feature-Policy) header is missing. Browser features are not restricted.

Remediation: Add Permissions-Policy header to restrict features: Permissions-Policy: geolocation=(), camera=(), microphone=()

Evidence: Header 'permissions-policy' not found in response

[MEDIUM] Forms Missing CSRF Protection

CVSS Score: 5.3 | **Category:** CSRF | **CWE:** CWE-352

Description: Found 1 form(s) without visible CSRF token protection.

Remediation: Implement CSRF tokens in all state-changing forms.

Evidence: 1 forms without csrf tokens detected

[MEDIUM] Potential HTTP Request Smuggling Vector

CVSS Score: 5.3 | **Category:** HTTP Protocol | **CWE:** CWE-444

Description: The server accepts requests with conflicting Content-Length and Transfer-Encoding headers, which may indicate vulnerability to HTTP request smuggling.

Remediation: Configure the server to reject requests with conflicting Content-Length and Transfer-Encoding headers. Ensure proper HTTP parsing at all layers.

Evidence: Server accepted request with both Content-Length and Transfer-Encoding headers. Response status: 200

[MEDIUM] WordPress User Enumeration via REST API

CVSS Score: 5.3 | **Category:** CMS Security | **CWE:** CWE-200

Description: User enumeration is possible through the WordPress REST API.

Remediation: Disable user enumeration by restricting access to /wp-json/wp/v2/users endpoint.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/wp-json/wp/v2/users> Status: 200

[MEDIUM] WordPress Uploads Directory Listing

CVSS Score: 5.3 | **Category:** CMS Security | **CWE:** CWE-200

Description: Directory listing is enabled on uploads folder.

Remediation: Disable directory listing or add index file.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/wp-content/uploads/> Status: 200

[LOW] Server Version Disclosure

CVSS Score: 2.6 | **Category:** Information Disclosure | **CWE:** CWE-200

Description: The Server header reveals web server software and version information.

Remediation: Remove or obfuscate the Server header to hide implementation details.

Evidence: server: Microsoft-IIS/8.5

[LOW] ASP.NET Version Disclosure

CVSS Score: 2.6 | **Category:** Information Disclosure | **CWE:** CWE-200

Description: X-AspNet-Version header reveals the ASP.NET version.

Remediation: Remove X-AspNet-Version header via web.config or IIS configuration.

Evidence: x-aspnet-version: 2.0.50727

[LOW] WordPress XML-RPC Enabled

CVSS Score: 3.7 | **Category:** CMS Security | **CWE:** CWE-200

Description: XML-RPC is enabled which can be used for brute-force attacks.

Remediation: Disable XML-RPC if not needed or use a plugin to restrict access.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/xmlrpc.php> Status: 200

[LOW] WordPress Version Exposed

CVSS Score: 2.0 | **Category:** CMS Security | **CWE:** CWE-200

Description: WordPress readme.html reveals version information.

Remediation: Remove or restrict access to readme.html.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/readme.html> Status: 200

[LOW] WordPress Includes Directory Accessible

CVSS Score: 2.0 | **Category:** CMS Security | **CWE:** CWE-200

Description: WordPress includes directory is accessible.

Remediation: Restrict access to wp-includes directory.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/wp-includes/> Status: 200

[INFO] Robots.txt Found

CVSS Score: 0.0 | **Category:** Sensitive Path Exposure

Description: Sensitive path '/robots.txt' is accessible (HTTP 200).

Remediation: Restrict access to this path or remove it from production.

Evidence: URL: <http://testaspnet.vulnweb.com/robots.txt>, Status: 200, Size: 13

[INFO] API Endpoints Discovered (38 found)

CVSS Score: 0.0 | **Category:** Information

Description: Discovered 38 API endpoints.

Remediation: Ensure all API endpoints have proper authentication and authorization.

Evidence: Endpoints: /api/, /swagger.yaml, /api/docs, /.well-known/openid-configuration, /api/swagger, /swagger/, /api/login, /v1, /api/profile, /swagger.json

[INFO] Hidden Parameters Discovered (98 found)

CVSS Score: 0.0 | **Category:** Information

Description: Discovered 98 potentially active parameters.

Remediation: Test discovered parameters for injection vulnerabilities.

Evidence: Parameters: from, page, tpl, api_key, authorization, filepath, cb, username, dir, doc

[INFO] WordPress REST API Accessible

CVSS Score: 0.0 | **Category:** CMS Security | **CWE:** CWE-200

Description: WordPress REST API is accessible.

Remediation: Review REST API endpoints for sensitive data exposure.

Evidence: Accessible at: <http://testaspnet.vulnweb.com/login.aspx/wp-json/> Status: 200